

Application: Car Booking Web Portal

Identified Vulnerabilities and Fixes:

1. Database credentials were hard-coded with the MySQL root user. The connection layer now loads credentials from environment variables, enables strict mysqli error handling and terminates safely on failure.
2. Multiple SQL injection risks existed in login, registration and booking flows. All inputs are now processed through parameterised prepared statements.
3. Passwords were stored with unsalted MD5 hashes. The system now uses PHP password_hash() and upgrades any legacy hashes transparently on the next successful login.
4. Public forms were missing CSRF protection. Each critical form now embeds a session-bound anti-CSRF token that is verified on submission.
5. Sessions were vulnerable to fixation after authentication. Successful logins regenerate the session identifier and clear stale session attributes on logout.
6. User supplied values were rendered without escaping, enabling stored XSS via vehicle data and booking records. All dynamic output paths now escape HTML entities.
7. Registration accepted weak data and duplicate emails. Server-side validation now enforces strong passwords, normalised phone numbers and rejects email collisions, including OAuth linked accounts.

OAuth 2.0 Integration:

- Implemented Google Authorization Code login with explicit state tracking, secure token exchange and userinfo retrieval. Accounts are created or linked seamlessly and stored with provider metadata for future logins.

Unresolved Items:

- Rate limiting and multi-factor authentication were noted as future enhancements beyond the current scope.

Preventive Best Practices:

- Adopt secure coding guidelines, peer reviews and automated security testing to detect issues early. Centralise credential management, require prepared statements, enforce password policies and include security checks in the CI pipeline.